

Cybersécurité

Principes · menaces · accès · appareils et réseaux · cryptographie · réaction à incident

☒ à faire · ☒ à éviter · ☒ piège fréquent

●●●○ robustesse relative (classement indicatif)

italique : terme anglais d'usage courant

→ étape suivante · **gras** : notion-clé

CE QUE L'ON PROTÈGE	
CRITÈRE	L'INFORMATION EST...
Disponibilité	accessible quand il le faut <i>atteinte : site saturé, fichiers chiffrés par rançongiciel</i>
Intégrité	exacte, non altérée <i>atteinte : RIB modifié dans une facture</i>
Confidentialité	réservée aux ayants droit <i>atteinte : fichier clients divulgué</i>
Traçabilité	on sait qui a fait quoi, et quand <i>moyen : journaux d'accès</i>

En anglais : triade **CIA** (*confidentiality, integrity, availability*). On y ajoute l'**authenticité** (l'origine est bien celle annoncée) et la **non-répudiation** (impossible de nier une action).

LE VOCABULAIRE DU RISQUE	
Actif	ce qui a de la valeur : données, service, matériel, réputation
Menace	cause possible d'un incident (un acteur, un événement)
Vulnérabilité	faiblesse exploitable : défaut logiciel, mauvaise configuration, erreur humaine
Exploit	code ou technique qui tire parti d'une vulnérabilité
Impact	conséquence si la menace se réalise
Risque	≈ vraisemblance × impact d'une menace exploitant une vulnérabilité
Mesure	ce qui réduit la vraisemblance ou l'impact
Risque résiduel	ce qui reste après les mesures, accepté en connaissance de cause

TRAITER UN RISQUE : QUATRE OPTIONS	
Réduire (mesures) · transférer (assurance, prestataire) · éviter (renoncer à l'activité) · accepter (décision explicite et tracée).	

QUI ATTAQUE, ET POURQUOI ?	
Cybercriminels	argent : rançon, fraude, revente de données et d'accès
États, groupes affiliés (APT)	espionnage, sabotage, déstabilisation
Hacktivistes	cause idéologique, visibilité (saturation, défiguration)
Initiés	vengeance, appât du gain — ou simple négligence
Opportunistes	défi, curiosité, outils prêts à l'emploi

Contre les particuliers et les petites structures, les attaques sont surtout **opportunistes et automatisées** : personne n'est « trop petit pour être visé ».

PRINCIPES DE CONCEPTION	
Moindre privilège	chaque compte n'a que les droits nécessaires, le temps nécessaire
Défense en profondeur	plusieurs couches indépendantes : la chute de l'une n'ouvre pas tout
Séparation des privilèges	compte d'administration distinct du compte quotidien ; double validation des opérations sensibles
Surface d'attaque minimale	désactiver ce qui ne sert pas : services, ports, comptes, extensions
Sécurité par défaut	le réglage le plus sûr d'emblée ; toute ouverture est une décision
Besoin d'en connaître	l'accès à une information se justifie par la mission
Zéro confiance (zero trust)	aucun réseau n'est « sûr » par nature : chaque accès est vérifié
Principe de Kerckhoffs	la sécurité repose sur le secret de la clé , pas sur celui du procédé : pas de « sécurité par l'obscurité »
Maillon faible	un système vaut ce que vaut son point le plus faible — souvent l'humain ou la récupération de compte

IDÉES REÇUES	
« Je n'ai rien d'intéressant. »	Vos comptes, votre identité, votre machine et vos contacts ont une valeur marchande.
« J'ai un antivirus, je suis protégé. »	Il n'empêche ni l'hameçonnage ni l'exploitation d'un mot de passe réutilisé.
« Le cadenas prouve que le site est sûr. »	Il prouve le chiffrement et le nom de domaine, pas l'honnêteté du site.
« Un mot de passe complexe suffit. »	Réutilisé, il tombe à la première fuite, où qu'elle ait lieu.
« Mon nuage synchronisé me sauvegarde. »	Il propage aussi les suppressions et le chiffrement.
« Payer la rançon rend les données. »	Aucune garantie, et l'on finance la prochaine attaque.
« Les pirates sont des génies. »	La plupart des attaques sont automatisées ou reposent sur la manipulation.

DOUZE RÉFLEXES D'HYGIÈNE NUMÉRIQUE	
1	Mettre à jour système, applications, box, téléphone — automatiquement.
2	Un mot de passe long et unique par service, conservé dans un gestionnaire .
3	Activer la double authentification , d'abord sur la messagerie et la banque.
4	Sauvegarder , dont une copie hors ligne ; tester la restauration.
5	Se méfier de l' urgence : un message pressant est un signal d'alerte.
6	Vérifier par un autre canal (numéro officiel, adresse tapée soi-même) toute demande sensible.
7	N'installer que depuis les sources officielles .
8	Travailler au quotidien avec un compte sans droits d'administration .
9	Chiffrer et verrouiller ordinateur et téléphone.
10	Séparer usages personnels et professionnels.
11	Limiter ce que l'on publie : chaque détail nourrit l'ingénierie sociale.
12	Signaler tôt et demander de l'aide : un incident caché s'aggrave.

AVANT DE CLIQUER, PAYER OU RÉPONDRE	
1	Est-ce que j'attendais ce message, cet appel, cette demande ?
2	Me presse-t-on , me fait-on peur , me promet-on un gain ?
3	Puis-je vérifier par un autre canal , que je choisis moi-même ?

Un doute suffit : ne pas agir, vérifier d'abord. Aucun organisme sérieux ne reproche à quelqu'un d'avoir pris le temps de rappeler.

CADRE LÉGAL (FRANCE)	
•	Accéder ou se maintenir fraudemusement dans un système : 3 ans et 100 000 € ; 5 ans et 150 000 € en cas de suppression ou modification de données ou d'altération du fonctionnement (C. pén., art. 323-1).
•	Entraver un système, y introduire ou modifier des données, détenir ou diffuser sans motif légitime un outil conçu pour ces atteintes : art. 323-2 à 323-3-1.
•	Ne tester que ses propres systèmes, un laboratoire isolé, une plateforme d'entraînement — ou avec une autorisation écrite du responsable (périmètre, dates).
•	RGPD : une violation de données personnelles se notifie à la CNIL sous 72 h (art. 33) ; les personnes sont informées si le risque est élevé (art. 34).

RECONNAÎTRE UN HAMEÇONNAGE (phishing)

SIGNAUX D'ALERTE

X

Urgence, menace ou gain : « compte suspendu », « colis bloqué », « remboursement », « amende impayée ».

X

Domaine approchant : paypa1.com, împots-gouv.info (exemples).

X

Lien trompeur : la cible réelle diffère du texte (survoler ; appui long sur mobile).

X

Pièce jointe inattendue : .zip, .iso, .html, .js, document qui demande d'« activer le contenu ».

X

Demande de secret : identifiant, code reçu par SMS, coordonnées bancaires, « validation » d'une opération.

!

Un texte sans faute ne prouve rien : l'IA générative rédige des messages impeccables et personnalisés.

LIRE UN DOMAINE

Le domaine réel est la partie **juste avant le premier « / »**, lue de droite à gauche :
https://banque.fr.**secure-login.net**/compte
→ le site visité est **secure-login.net**, pas banque.fr.

VARIANTES

Smishing : par SMS · vishing : par téléphone (faux conseiller bancaire, faux policier) · quishing : par QR code · spear phishing : ciblé · **fraude au président, au RIB** : faux dirigeant ou faux fournisseur exigeant un virement urgent.

Règle d'or — ne jamais répondre par le canal reçu. Rappeler l'organisme au numéro connu, taper soi-même l'adresse. Une banque ne demande jamais de valider une opération pour l'« annuler ».

LEVIERIS DE L'INGÉNIERIE SOCIALE

Autorité	« Ici la direction, la police, le support informatique. »
Urgence	« Avant 17 h, sinon le compte est bloqué. »
Peur	menace de poursuites, de piratage, de publication
Appât, rareté	gain, cadeau, « photo de vous », offre limitée
Réciprocité	rendre service à qui vient de vous aider
Preuve sociale	« Vos collègues ont déjà fait la mise à jour. »
Sympathie	ton amical, connaissance commune, voix d'un proche imitée

Parade : ralentir, vérifier, en parler. Une procédure écrite (double validation des virements, rappel systématique au numéro connu) protège mieux que la seule vigilance.

SIGNES D'UNE COMPROMISSION

!

Mot de passe soudain refusé ; alertes de connexion ou de modification que l'on n'a pas demandées.

!

Messages partis à votre insu ; courriels disparus ; règle de transfert inconnue.

!

Opérations ou achats inconnus ; codes de validation reçus sans rien avoir demandé.

!

Nouveaux programmes, extensions ou page d'accueil ; protection désactivée.

!

Lenteurs, fenêtres intempestives, activité réseau inexpliquée : indices faibles, pas des preuves.

Dans le doute : les premiers gestes de la page 6.

LOGICIELS MALVEILLANTS (malware)

Virus	s'attache à un fichier ou programme ; se propage quand on l'exécute
Ver (worm)	se propage seul par le réseau en exploitant une faille
Cheval de Troie (trojan)	se fait passer pour un programme légitime
Rançongiciel (ransomware)	chiffre les données et exige une rançon ; souvent vol préalable et menace de publication (double extorsion)
Voleur d'informations (infostealer)	aspire mots de passe enregistrés, cookies de session, portefeuilles
Logiciel espion, enregistreur de frappe (spyware, keylogger)	observe et transmet
Accès à distance (RAT), porte dérobée	prise de contrôle durable
Rootkit	se dissimule au cœur du système
Réseau de zombies (botnet)	machines infectées pilotées ensemble : saturation, spam
Cryptomineur	détourne la puissance de calcul
Effaceur (wiper)	détruit les données : sabotage

ANATOMIE D'UNE INTRUSION — chaîne d'attaque (Cyber Kill Chain), Lockheed Martin, 2011

1

Reconnaissance sources ouvertes, balayage des services exposés

2

Armement document piégé, lien, charge malveillante

3

Livraison courriel, site, clé USB, fournisseur

4

Exploitation une faille ou un clic exécute le code

5

Installation persistance sur la machine

6

Commande et contrôle (C2) pilotage à distance

7

Actions sur l'objectif vol, chiffrement, sabotage

Chaque maillon rompu arrête l'attaque : c'est la logique de la défense en profondeur. Version détaillée : **MITRE ATT&CK**, catalogue des techniques observées.

ATTAQUES COURANTES ET PARADES		
ATTAQUE	PRINCIPE	PARADE
Force brute	essayer toutes les combinaisons	longueur, limitation des essais, MFA
Bourrage d'identifiants (credential stuffing)	rejouer des couples identifiant / mot de passe issus de fuites	un mot de passe unique par service, MFA
Pulvérisation (password spraying)	quelques mots de passe courants essayés sur beaucoup de comptes	liste de mots de passe interdits, MFA
Homme du milieu (MitM)	s'interposer dans une communication	HTTPS / TLS, alerte de certificat prise au sérieux
Déni de service (DDoS)	saturer un service de requêtes	filtrage, surdimensionnement, prestataire anti-DDoS
Injection (SQL, commande)	des données sont interprétées comme du code	requêtes paramétrées, validation des entrées
Script intersite (XSS)	script injecté dans une page consultée par d'autres	échappement des sorties, politique CSP
Détournement de SIM (SIM swapping)	obtenir un duplicata de la carte SIM de la victime	pas de SMS comme seul second facteur des comptes vitaux
Fatigue MFA (MFA bombing)	inonder de demandes d'approbation jusqu'au « oui »	correspondance de nombre, clé FIDO2 ; ne jamais approuver sans action de sa part
Vol de session	réutiliser un cookie de connexion volé (contourne la MFA)	se déconnecter, sessions courtes, antivirus contre les voleurs d'informations
Chaîne d'approvisionnement	compromettre un fournisseur, une mise à jour, une dépendance	inventaire, signatures, provenance vérifiée
Hypertrucage (deepfake)	voix ou vidéo d'un proche, d'un dirigeant imitée	question de contrôle, mot convenu, rappel
Faux support technique	fenêtre bloquante et numéro à appeler	fermer le navigateur ; jamais d'accès à distance à un inconnu

QUATRE NOTIONS À DISTINGUER

Identification	dire qui l'on est — <i>identifiant</i>
Authentification	le prouver — <i>mot de passe, clé, biométrie</i>
Autorisation	ce que l'on a le droit de faire — <i>rôles, droits</i>
Traçabilité	garder trace de ce qui a été fait — <i>journaux</i>

LES FACTEURS D'AUTHENTIFICATION

Ce que je sais	mot de passe, phrase de passe, code PIN
Ce que je possède	téléphone, clé de sécurité, carte à puce
Ce que je suis	empreinte, visage — ne se change pas en cas de fuite ; sert surtout à déverrouiller un secret local

Authentification multifacteur (MFA) : au moins deux facteurs de **catégories différentes**. Deux mots de passe ne font pas une MFA.

SECOND FACTEUR : DU PLUS FAIBLE AU PLUS FORT

MÉTHODE	FORCE	LIMITE
Code par SMS ou appel	●○○○	interception, détournement de SIM ; recopiable sur un faux site
Code par courriel	●○○○	ne vaut que ce que vaut la messagerie
Application de codes (TOTP)	●●○○	code de 6 chiffres renouvelé toutes les 30 s ; recopiable sur un faux site
Notification à approuver	●●○○	fatigue MFA ; ●●●○ avec correspondance de nombre
Clé FIDO2, clé d'accès (passkey)	●●●●	résiste à l'hameçonnage : liée au vrai nom de domaine

Tout second facteur vaut mieux qu'aucun.
Conserver les **codes de secours** imprimés, à l'abri.

CLÉS D'ACCÈS (passkeys)

- Remplacent le mot de passe par une **paire de clés** : la clé publique chez le service, la clé privée dans l'appareil ou le gestionnaire, débloquée par code ou biométrie.
- Aucun secret n'est transmis au site ; une fuite chez le service ne livre rien d'utilisable.
- Liées au nom de domaine : un faux site ne peut pas les solliciter → **résistantes à l'hameçonnage**.
- Standard FIDO2 / WebAuthn. Enregistrer deux appareils ou activer la synchronisation pour ne pas perdre l'accès.

MOTS DE PASSE : LES RÈGLES ACTUELLES

- ✓ **Longueur avant complexité** : la longueur fait l'essentiel de la robustesse.
- ✓ **Un mot de passe par service** : une fuite n'ouvre qu'une porte.
- ✓ Tiré **au hasard** par un générateur, conservé dans un **gestionnaire**.
- ✓ Le changer **en cas de compromission** ou de doute, pas par rituel.
- ✓ Vérifier ses adresses dans les fuites connues (haveibeenpwned.com).
- ✗ Réutiliser, ou décliner : « Soleil2025! » → « Soleil2026! ».
- ✗ Dates, prénoms, animal, club, ville : tout ce qui se trouve en ligne.
- ✗ Répondre vrai aux questions secrètes : y mettre une réponse aléatoire, notée dans le gestionnaire.
- ✗ Transmettre un mot de passe par courriel, SMS ou messagerie.

REPÈRES OFFICIELS (VÉRIFIÉS LE 28/09/2026)

CNIL délib. 2022-100	Mot de passe seul : 80 bits d'entropie, soit par ex. 12 caractères (majuscules, minuscules, chiffres, spéciaux), 14 sans spécial obligatoire, ou une phrase de passe de 7 mots . Avec limitation des essais : 50 bits. Avec un matériel détenu et blocage après 3 essais (carte, téléphone) : 13 bits, soit un code PIN.
NIST SP 800-63B-4, 2025	15 caractères minimum si le mot de passe est seul, 8 s'il s'inscrit dans une MFA ; aucune règle de composition imposée ; pas de renouvellement périodique ; filtrage des mots de passe compromis ou courants ; au moins 64 caractères acceptés.

LE GESTIONNAIRE DE MOTS DE PASSE

- Coffre **chiffré**, ouvert par un **mot de passe maître** (longue phrase de passe jamais réutilisée) et, si possible, une MFA.
- Génère et retient des mots de passe uniques ; ne remplit que sur le **vrai domaine** : protection contre l'hameçonnage.
- Local** (fichier chiffré à sauvegarder) ou **synchronisé** (service en ligne, chiffrement côté client). Exemples libres : KeePassXC (local), Bitwarden (synchronisé).
- Prévoir l'**accès de secours** : kit d'urgence imprimé, rangé en lieu sûr ; penser à la transmission.

NE PAS SE FERMER LA PORTE

- Imprimer les **codes de secours** des comptes importants ; les ranger avec le kit d'urgence.
- Tenir à jour adresse et numéro de récupération ; éviter qu'ils dépendent d'un seul appareil.
- Enregistrer **deux** facteurs forts (deux clés, ou clé + application) pour ne pas se verrouiller dehors.

MESURER LA FORCE : L'ENTROPIE

Entropie en bits = $\log_2$ du nombre de possibilités ; **chaque bit double** le travail de l'attaquant. Le calcul ne vaut que pour un tirage **au hasard** : « Toulouse1990! » est bien plus faible que ses 13 caractères ne le laissent croire.

CONSTRUCTION ALÉATOIRE	BITS
8 caractères du clavier (95 signes)	≈ 53
12 caractères du clavier	≈ 79
16 caractères du clavier	≈ 105
20 lettres minuscules (26 signes)	≈ 94
5 mots tirés d'une liste de 7 776 (dés)	≈ 65
7 mots tirés d'une liste de 7 776	≈ 90

PHRASE DE PASSE

Tirer 5 à 7 mots **au hasard** (dés, générateur), jamais une citation ni un vers connu : girafe-tonnerre-lentille-abricot-parvis-muscade-reflet (exemple publié : ne pas l'utiliser).

COMMENT UN MOT DE PASSE TOMBE

Fuite puis réutilisation	la cause la plus simple : un site piraté livre le couple identifiant / mot de passe, rejoué partout
Hameçonnage	l'utilisateur le saisit lui-même sur un faux site
Logiciel espion	voleur d'informations, enregistreur de frappe
Attaque en ligne	essais sur la page de connexion : freinée par la limitation des essais
Attaque hors ligne	sur une base d'empreintes volée : des milliards d'essais par seconde sur carte graphique si le hachage est rapide, bien moins avec Argon2id ou bcrypt (ordre de grandeur)
Dictionnaire et règles	mots courants, prénoms, dates, substitutions (a → @, e → 3), chiffre ou « ! » final : testés en premier

Un mot de passe **aléatoire, long et unique** déjoue la réutilisation et toutes les attaques par essais. Contre l'hameçonnage et l'espionnage, il faut en plus un gestionnaire qui ne remplit que sur le vrai domaine, une MFA résistante à l'hameçonnage et un poste sain.

LA MESSAGERIE, CLÉ DE VOÛTE

- Elle sert à **réinitialiser tous les autres comptes** : la protéger en premier (mot de passe unique, MFA forte).
- Contrôler régulièrement : adresse et numéro de récupération, **règles de transfert** automatique, applications autorisées, sessions et appareils connectés.
- Compte d'**administration** distinct, réservé à l'administration : jamais pour naviguer ni lire le courrier.
- Poste partagé : navigation privée, déconnexion, aucun mot de passe enregistré.

4 · Appareils, réseaux, données

MISES À JOUR

- Un correctif ferme une vulnérabilité **rendue publique** : les attaquants l'étudient dès sa sortie ; le délai compte.
- Mises à jour **automatiques** : système, navigateur, applications, micrologiciel (*firmware*) de la box et des objets connectés.
- Système ou logiciel **en fin de support** = plus aucun correctif : le remplacer ou l'isoler.
- Désinstaller ce qui ne sert plus : moins de logiciels, moins de failles.
- Télécharger chez l'éditeur ou dans le magasin officiel ; se méfier des **annonces sponsorisées** en tête des moteurs de recherche.

SAUVEGARDE : LA RÈGLE 3-2-1

3 copies des données **2** supports différents **1** copie hors site

Variante **3-2-1-1-0** : + 1 copie **hors ligne** ou **non modifiable**, + 0 erreur lors d'une restauration testée.

- Synchronisation ≠ sauvegarde** : un nuage synchronisé propage aussi les suppressions et le chiffrement par rançongiciel. Il faut des **versions** et une copie déconnectée.
- Types : **complète** · **incrémentale** (ce qui a changé depuis la dernière sauvegarde) · **différentielle** (depuis la dernière complète).
- Une sauvegarde jamais restaurée n'est qu'une hypothèse : **tester**.
- Débrancher le disque de sauvegarde après usage ; chiffrer les copies hors site.

DEUX QUESTIONS DE CONTINUITÉ

RPO (*recovery point objective*) : quelle perte de données est tolérable ? → fréquence des sauvegardes

RTO (*recovery time objective*) : en combien de temps redémarrer ? → méthode de restauration

EN DÉPLACEMENT

- Sur un Wi-Fi public, HTTPS protège le contenu échangé ; le danger vient surtout des **faux points d'accès** et des pages de connexion piégées.
- Opérations sensibles : préférer le **partage de connexion** de son téléphone.
- Désactiver le partage de fichiers et la connexion automatique aux réseaux ouverts.
- Bornes USB publiques : recharger sur secteur avec son propre adaptateur, ou câble « charge seule ».

ORDINATEUR

- Compte quotidien **sans droits d'administration**.
- Protection intégrée active : antivirus, pare-feu, filtrage des téléchargements.
- Disque chiffré** (BitLocker, FileVault, LUKS) ; clé de récupération conservée hors de l'appareil.
- Verrouillage automatique ; verrouiller en s'éloignant (Win + L).
- Macros bloquées par défaut ; extensions du navigateur réduites au nécessaire.
- Brancher une clé USB trouvée ou offerte.
- Logiciels piratés, « cracks », générateurs de clés : vecteur fréquent de voleurs d'informations.

TÉLÉPHONE

- Code de verrouillage de 6 chiffres ou plus, biométrie ; **code PIN de la carte SIM**.
- Mises à jour ; applications du magasin officiel ; **permissions** revues (micro, localisation, contacts, SMS).
- Localisation et **effacement à distance** activés ; sauvegarde activée.
- Noter le numéro **IMEI** (composer *#06#) et le garder à part : il permet de bloquer l'appareil volé.
- Installer une application reçue par lien ou SMS.
- Accorder le service d'**accessibilité** ou l'administration de l'appareil à une application inconnue.

NAVIGATEUR

- Navigateur et extensions à jour ; extensions peu nombreuses, d'éditeurs identifiés.
- Prendre au sérieux les alertes : certificat invalide, site signalé dangereux, téléchargement bloqué.
- Sites sensibles (banque, impôts) : adresse tapée soi-même ou favori.
- Le gestionnaire de mots de passe ne propose rien sur une page de connexion ? Vérifier l'adresse : c'est peut-être un faux site.
- Un bloqueur de publicités réduit l'exposition aux publicités piégées (*malvertising*).
- Autoriser les notifications d'un site inconnu : elles servent à diffuser des arnaques.
- Installer un « lecteur » ou une « mise à jour » proposés par une page web.

RÉSEAU DOMESTIQUE

- Mot de passe d'administration de la box changé ; micrologiciel à jour.
- Wi-Fi en **WPA3** (à défaut WPA2-AES) avec une clé longue ; **WPS désactivé**.
- Réseau invité** pour visiteurs et objets connectés.
- Exposer un service sur Internet sans nécessité : redirection de ports, UPnP, bureau à distance.

DÉFENSE EN PROFONDEUR (ORGANISATION)

Personnes	sensibilisation, procédures, exercices
Identités	MFA, comptes à privilèges séparés et surveillés
Postes	durcissement, EDR (détection et réponse sur le poste)
Réseau	pare-feu, segmentation, zone tampon (DMZ), VPN, détection d'intrusion (IDS / IPS)
Applications	développement sûr, pare-feu applicatif (WAF)
Données	chiffrement, sauvegardes, droits d'accès
Supervision	journaux centralisés (<i>SIEM</i>), centre opérationnel (<i>SOC</i>)

OBJETS CONNECTÉS

Changer le mot de passe par défaut · mettre à jour · les placer sur le **réseau invité** · couper micro et caméra inutilisés · se demander si la connexion est nécessaire.

DONNÉES ET VIE PRIVÉE

- Chiffrer **au repos** (disque, archive) et **en transit** (TLS, messagerie chiffrée de bout en bout).
- Minimiser** : ce qui n'est pas collecté ne peut pas fuir.
- Métadonnées** : position GPS des photos (EXIF), auteur et révisions des documents.
- Liens de partage : durée limitée, mot de passe ; jamais « toute personne disposant du lien » pour du sensible.
- Céder un appareil : chiffrement puis réinitialisation d'usine ; disque dur ancien : effacement sécurisé ou destruction.
- Réseaux sociaux : ce qui est publié (naissance, école, voyages) nourrit la **recherche en sources ouvertes (OSINT)** des attaquants.

CE QU'ILS PROTÈGENT — ET CE QU'ILS NE PROTÈGENT PAS

OUTIL	PROTÈGE	NE PROTÈGE PAS
Cadenas HTTPS	le trajet jusqu'au site ; l'identité du nom de domaine	l'honnêteté du site : un faux site a aussi son cadenas
VPN	le trajet jusqu'au fournisseur ; masque l'adresse IP aux sites	ni anonymat, ni hameçonnage, ni logiciel malveillant ; la confiance est déplacée vers le fournisseur
Navigation privée	n'enregistre pas l'historique sur l'appareil	ne rend pas anonyme vis-à-vis des sites, du réseau, de l'employeur

5 · Cryptographie, vulnérabilités, référentiels

MÉMENTO — CYBERSÉCURITÉ

LES BRIQUES DE LA CRYPTOGRAPHIE				
BRIQUE	SERT À	PRINCIPE	EXEMPLES ACTUELS	À PROSCRIRE
Chiffrement symétrique	confidentialité	une même clé chiffre et déchiffre ; rapide	AES-128 / 256 (mode GCM), ChaCha20-Poly1305	DES, 3DES, RC4, mode ECB
Asymétrique, échange de clés	établir une clé commune ; chiffrer pour un destinataire	clé publique diffusée, clé privée gardée	RSA ≥ 3072 bits, ECDH (X25519, P-256)	RSA de 1024 bits ou moins
Hachage	empreinte, intégrité	sens unique, taille fixe ; avec une clé secrète : code d'authentification (MAC)	SHA-256, SHA-384, SHA-3 ; HMAC-SHA-256	MD5, SHA-1
Hachage de mots de passe	stocker un mot de passe	volontairement lent , avec un sel aléatoire par compte	Argon2id, scrypt, bcrypt, PBKDF2	stockage en clair, hachage rapide sans sel
Signature numérique	authenticité, intégrité, non-répudiation	signer avec la clé privée , vérifier avec la clé publique	Ed25519, ECDSA P-256, RSA-PSS	signatures MD5 ou SHA-1
Post-quantique	résister à un futur ordinateur quantique	nouveaux problèmes mathématiques (réseaux euclidiens, hachage)	ML-KEM, ML-DSA, SLH-DSA (normes NIST FIPS 203-205, 2024), en hybridation avec un algorithme classique	—

Un grand ordinateur quantique casserait RSA et les courbes elliptiques : menace « **collecter maintenant, déchiffrer plus tard** ». L'ANSSI (guide des mécanismes cryptographiques v3.00, mars 2026) exige une sécurité post-quantique pour les mécanismes employés après le 1^{er} janvier 2030. Tailles et algorithmes : état de l'art courant, à confronter au guide avant tout choix réel.

NE PAS CONFONDRE	
Encoder	changer de format (Base64, URL) ; réversible par tous : aucune protection
Chiffrer	réversible seulement avec la clé
Hacher	irréversible ; on compare des empreintes
Signer	prouver l'origine et l'intégrité
De bout en bout	seuls les correspondants détiennent les clés ; le fournisseur ne peut pas lire
En transit	chiffré sur le trajet, mais lisible par le serveur

COMMENT FONCTIONNE HTTPS (TLS)	
1	Le navigateur propose des algorithmes ; le serveur présente son certificat : sa clé publique, signée par une autorité de certification (AC).
2	Le navigateur vérifie la chaîne de confiance jusqu'à une AC racine connue, le nom de domaine et la validité.
3	Échange de clés éphémère (ECDHE) → clé de session symétrique .
4	Les échanges sont chiffrés et authentifiés.
Confidentialité persistante (<i>forward secrecy</i>) : voler plus tard la clé du serveur ne déchiffre pas les échanges passés. Versions : TLS 1.3 à privilégier, 1.2 acceptable bien configuré ; SSL, TLS 1.0 et 1.1 obsolètes.	

HYGIÈNE CRYPTOGRAPHIQUE	
• Ne jamais inventer son algorithme ni son protocole : bibliothèques éprouvées et maintenues.	
• Clés produites par un générateur aléatoire cryptographique ; jamais écrites dans le code ni dans un dépôt Git.	
• Clés rangées dans un coffre (gestionnaire de secrets, module matériel, carte à puce) ; renouvelées ; révoquées en cas de fuite.	
• Agilité : pouvoir changer d'algorithme sans tout refaire — la transition post-quantique l'exige.	

VIE D'UNE VULNÉRABILITÉ	
découverte	→ signalement à l'éditeur →
identifiant CVE	→ correctif → avis de sécurité
→ déploiement	
• Faible « jour zéro » (0-day) : exploitée avant tout correctif.	
• Faible connue non corrigée (n-day) : le correctif existe mais n'est pas appliqué — cas très fréquent.	
• Divulgaration coordonnée : laisser à l'éditeur le temps de corriger ; programmes de primes (<i>bug bounty</i>).	

IDENTIFIANTS ET SCORES

CVE

identifiant unique d’une vulnérabilité : CVE-2021-44228 (Log4Shell)

CWE

type de faiblesse : CWE-79 = XSS, CWE-89 = injection SQL

CVSS

gravité technique de 0 à 10 (version 4.0, FIRST, 2023)

EPSS

probabilité d’exploitation dans les 30 jours (FIRST)

KEV

catalogue des failles **effectivement exploitées** (CISA, États-Unis)

CERT-FR

avis et alertes de sécurité en français

ÉCHELLE CVSS

Aucune	Faible	Moyenne	Élevée	Critique
0,0	0,1 – 3,9	4,0 – 6,9	7,0 – 8,9	9,0 – 10

Prioriser en croisant : exploitation avérée (KEV), probabilité (EPSS), gravité (CVSS) et exposition de l’actif concerné.

OWASP TOP 10 : 2025 (applications web)	
A01	Contrôle d'accès défaillant (inclut la falsification de requêtes côté serveur, SSRF)
A02	Mauvaise configuration de sécurité
A03	Défaillances de la chaîne d'approvisionnement logicielle
A04	Défaillances cryptographiques
A05	Injection
A06	Conception non sécurisée
A07	Défaillances d'authentification
A08	Défauts d'intégrité des logiciels ou des données
A09	Défaillances de journalisation et d'alerte
A10	Mauvaise gestion des conditions exceptionnelles
Traduction libre ; liste consultée le 28/09/2026 sur owasp.org . Révisée environ tous les quatre ans (2017, 2021, 2025).	

RÉFÉRENTIELS ET MÉTHODES	
NIST CSF 2.0 (2024)	six fonctions : gouverner, identifier, protéger, détecter, répondre, rétablir
ISO/IEC 27001	système de management de la sécurité de l'information, certifiable ; 27002 : catalogue de mesures
EBIOS Risk Manager	méthode française d'analyse de risques (ANSSI)
Guide d'hygiène (ANSSI)	42 mesures pour les organisations
MITRE ATT&CK	tactiques et techniques d'attaque observées
RGPD · NIS 2	données personnelles · directive européenne sur les entités essentielles et importantes (transposition française : à vérifier)

6 · Réagir à un incident

MÉMENTO — CYBERSÉCURITÉ

PREMIERS GESTES, QUELLE QUE SOIT LA SITUATION

1 Garder son calme ; ne pas payer, ne pas négocier

2 Isoler : couper le réseau sans éteindre

3 Conserver les preuves : captures, messages, dates, montants

4 Changer les accès depuis un appareil sain

5 Prévenir : banque, service concerné, responsable

6 Signaler et porter plainte

SITUATIONS COURANTES		
SITUATION	TOUT DE SUITE	ENSUITE
J'ai saisi un mot de passe sur un faux site	Le changer sur le vrai site, et partout où il était réutilisé ; activer la MFA	Vérifier sessions ouvertes, règles de transfert, adresse de récupération ; signaler le message
J'ai donné mes coordonnées bancaires ou validé une opération	Appeler la banque au numéro habituel ; faire opposition	Contester les opérations ; signalement Perceval ; plainte
Mon compte (messenger, réseau social) est piraté	Procédure officielle de récupération du service ; fermer toutes les sessions	Mot de passe neuf, MFA, applications autorisées revues ; prévenir ses contacts (escroqueries en votre nom)
Rançongiciel	Débrancher du réseau (câble, Wi-Fi) sans éteindre ; ne pas payer	Alerter le support ; plainte ; CNIL si données personnelles ; assureur ; nomoreransom.org ; réinstaller, restaurer des sauvegardes saines
Écran bloqué par un « support technique »	Ne pas appeler ; fermer le navigateur (gestionnaire des tâches : [Ctrl]+[Maj]+[Échap])	Si un accès à distance a été accordé : déconnecter, désinstaller l'outil, analyser, changer les mots de passe, prévenir la banque
Téléphone perdu ou volé	Localiser, verrouiller, effacer à distance ; faire suspendre la ligne	Plainte ; blocage par l'IMEI ; mots de passe changés ; appareil retiré des comptes
Mon adresse figure dans une fuite	Changer le mot de passe concerné et ceux qui lui ressemblent	MFA ; vigilance accrue face à l'hameçonnage ciblé
Chantage : sextorsion, menace de publication	Ne pas payer, ne pas répondre ; conserver les preuves	Signaler (17Cyber, Pharos) ; plainte ; si le mot de passe cité est réel, le changer
Appel d'un « conseiller bancaire »	Raccrocher ; rappeler soi-même la banque au numéro habituel	Ne jamais communiquer de code ni « valider pour sécuriser »

OÙ SIGNALER, OÙ TROUVER DE L'AIDE (FRANCE)

17cyber.gouv.fr — guichet unique d'assistance, 24 h / 24 : diagnostic, conseils, échange avec un policier ou un gendarme, mise en relation avec un prestataire

17 ou 112 — urgence : danger immédiat

internet-signalement.gouv.fr — Pharos : contenus illicites en ligne

33700 — SMS et appels frauduleux : transférer le SMS au 33700

signal-spam.fr — courriels indésirables et d'hameçonnage

phishing-initiative.fr — faire bloquer l'adresse d'un site d'hameçonnage

Perceval — usage frauduleux de sa carte bancaire (via service-public.fr)

THESEE — plainte en ligne pour certaines escroqueries sur Internet (via service-public.fr)

0 805 805 817 — Info Escroqueries : conseil et orientation, appel gratuit

cnil.fr — notification d'une violation de données (organismes) ; plaintes

nomoreransom.org — outils de déchiffrement de certains rançongiciels

Coordonnées vérifiées le 28/09/2026 ; elles peuvent changer.

PLAINTÉ : RÉUNIR LES PREUVES

- Captures d'écran avec la **date** et l'**adresse** du site ou le **numéro** de l'expéditeur.
- Courriel gardé tel quel, avec ses **en-têtes** (« afficher l'original »).
- Relevés, références et montants des opérations ; **chronologie** écrite des faits.

EN ORGANISATION : CYCLE DE RÉPONSE

préparer → détecter, analyser → contenir → éradiquer → rétablir → retour d'expérience

- Tenir une **main courante** horodatée : qui, quoi, quand.
- Ne rien effacer : conserver journaux, supports, messages de rançon.
- Communiquer par un **canal non compromis**.
- Violation de données personnelles : CNIL **sous 72 h**.
- Assurance (activité professionnelle) : l'indemnisation suppose une **plainte sous 72 h** (C. assur., art. L. 12-10-1).

Phases classiques des guides NIST SP 800-61 (rév. 2) et SANS ; la révision 3 (2025) les rattache aux six fonctions du CSF 2.0.

APPRENDRE SANS ENFREINDRE LA LOI

- Laboratoire personnel** : machines virtuelles isolées (réseau « hôte uniquement »), systèmes volontairement vulnérables.
- Plateformes d'entraînement** autorisées : Root-Me, TryHackMe, Hack The Box, OverTheWire, PortSwigger Web Security Academy ; compétitions CTF.
- S'informer** : cybermalveillance.gouv.fr (fiches réflexes), cyber.gouv.fr (guides de l'ANSSI), CERT-FR (alertes), SecNumacadémie (MOOC de l'ANSSI).
- Dater** chaque recommandation : l'état de l'art change vite.

GLOSSAIRE EXPRESS

Durcissement

réduire la configuration au strict nécessaire

Élévation de privilèges

passer de droits limités à des droits d'administration

Mouvement latéral

rebondir d'une machine compromise à d'autres

Exfiltration

sortie clandestine de données

Indicateur de compromission (IOC)

trace révélatrice : adresse, empreinte, domaine

Test d'intrusion (pentest)

attaque autorisée, bornée, suivie d'un rapport

Équipe rouge / bleue (red / blue team)

attaquants simulés / défenseurs

Bac à sable (sandbox)

environnement isolé pour ouvrir un fichier suspect

Pot de miel (honeypot)

leurre qui attire et observe les attaquants

Charge utile (payload)

partie du code malveillant qui produit l'effet recherché

Vecteur d'attaque

voie d'entrée : courriel, service exposé, clé USB, fournisseur

Jeton de session

preuve de connexion gardée par le navigateur (cookie) : le voler, c'est entrer sans mot de passe